

一种新型中间值碰撞能量分析攻击

杨国梁, 张海龙, 周永彬

中国科学院信息工程研究所

摘要: 典型能量分析攻击通常利用密码设备中密码算法细节实施攻击, 密码设备细节未知时此类能量分析攻击将失效。盲攻击适宜在攻击者对密码设备内部密码算法未知时使用。然而, 盲攻击假设攻击者具有对建模设备重写密钥的能力, 当攻击者无法对建模设备重写密钥时盲攻击应用会严重受限。基于此, 本文探讨攻击者对密码设备中密码算法所知有限, 建模设备数量有限, 并且攻击者无法对建模设备重写密钥场景中能量分析攻击地实施。具体地, 本文提出一种新型中间值碰撞能量分析攻击, 该方法利用明文与密钥交换后密码设备中密码算法某些中间值保持不变的碰撞特性对密码设备实施能量分析攻击。同时, 本文以实现于STC89C58微控制器的AES-128无保护软件实现为例验证了该攻击的有效性。

关键词: 中间值碰撞, 能量分析攻击, 侧信道密码分析。

1 引言

能量分析攻击利用密码设备运行过程中产生的能量消耗恢复密码设备所使用的密钥。典型能量分析攻击(例如, 差分能量分析[1]、相关能量分析[2, 3]、模板攻击[4]、互信息分析[5, 6, 7])地成功实施, 通常要求密码设备内部密码算法的细节已知。攻击者利用密码设备运行过程中产生的能量消耗与其中密码算法所产生中间值的统计依赖关系恢复密码设备所使用密钥。具体地, 攻击者基于所选取明文、假设密钥结合密码设备内部密码算法结构计算出一组假设中间值。攻击者基于某种能量泄露模型(例如, 汉明重量模型[1])将假设中间值映射为假设能量消耗。密钥猜测正确时, 假设能量消耗与真实能量消耗表现出较强的相关性; 反之, 假设能量消耗与真实能量消耗表现出较弱的相关性。攻击者通过比较由不同密钥猜测计算得到的假设能量消耗与真实能量消耗之间的相关性大小即可恢复密码设备所使用密钥。然而, 实际应用中攻击者通常对密码

设备中密码算法细节未知。此时，攻击者无法有效计算出假设能量消耗，典型能量分析攻击方法失效。

盲攻击[8] 假设攻击者不知道目标设备内部密码算法细节，但是，攻击者拥有一台与目标设备具有相似物理泄露特征的建模设备，同时攻击者具有更改建模设备所使用密钥的能力。首先为建模设备输入不同的密钥，利用从建模设备采集到的能量迹刻画出建模设备使用不同密钥时的能量泄露特性（亦称为模板）；其次，计算从目标设备采集到的能量迹与建模设备使用不同密钥时所刻画得到模板的匹配度。攻击者认为导致二者匹配度最高的密钥猜测为目标设备所使用密钥。显然，攻击者不具备对建模设备重写密钥的能力时，盲攻击难以实施。

通过分析已有能量分析攻击存在的问题，本文提出中间值碰撞能量分析攻击。该方法要求目标设备内部密码算法满足明文与密钥交换后某些中间值保持不变的条件，但不需要攻击者知道目标设备中密码算法细节，也不要求攻击者具有对建模设备重写密钥的能力。中间值碰撞能量分析攻击假设攻击者拥有少量与目标设备同类型的建模设备，不同建模设备所使用的密钥已知，且不尽相同。为验证该方法的有效性，本文对实现于STC89C58微控制器的AES-128无保护软件实现实施了攻击。攻击结果表明，该方法能有效恢复出目标设备所使用密钥。

最后需要说明，利用密码设备中密码算法中间值碰撞特性实施密钥恢复的思想已为侧信道密码分析人员所广泛采用，通常将此类密钥恢复方法称为侧信道碰撞攻击[9, 10, 11, 12]。然而，侧信道碰撞攻击需要分析人员知悉密码设备中密码算法细节。实际应用中，分析人员对密码设备内部密码算法细节未知时，侧信道碰撞攻击失效。

2 基础知识

本节对中间值碰撞能量分析攻击所涉及的基础知识进行简要介绍，包括能量迹的组成，皮尔逊相关系数基本原理，以及模板攻击工作原理。

2.1 能量迹的组成

Mangard等人[13]指出，能量迹中单个时刻能量泄露信息由操作依赖分量 P_{op} 、数据依赖分量 P_{data} 、电子噪声 $P_{el.nois}$ 、以及恒定分量 P_{const} 累加组成，如公式(1)所示。其中，操作依赖分量依赖于密码设备所执行的操作；数据依赖分量依赖于密码设备所处理的数据；电子噪声为测量过程中由于抖动、温度变化等因素造成的测量误差。除噪声之外，能量迹中单个时刻能量泄露信息还包

含一个常量部分。常量部分由漏电流以及与操作和数据无关的晶体管转换活动造成。

$$P_{total} = P_{op} + P_{data} + P_{el.nois} + P_{const} \quad (1)$$

2.2 皮尔逊相关系数

交叉碰撞能量分析攻击使用皮尔逊相关系数计算从目标设备采集到的能量迹与从建模设备采集到的能量迹之间的相关性。攻击者利用二者相关性大小恢复出目标设备所使用密钥。皮尔逊相关系数 ρ 的取值满足 $-1 \leq \rho \leq 1$ 。 ρ 越接近于1，表示两个变量之间的线性相关性越大。变量 X 与 Y 之间的皮尔逊相关系数计算见公式(2)，其中， X_i 与 Y_i 为变量 X 与 Y 的第 i 个样本， $\bar{X}$ 与 $\bar{Y}$ 分别表示变量 X 与 Y 的样本均值。

$$\rho_{X,Y} = \frac{\sum_{i=1}^n (X_i - \bar{X})(Y_i - \bar{Y})}{\sqrt{\sum_{i=1}^n (X_i - \bar{X})^2} \sqrt{\sum_{i=1}^n (Y_i - \bar{Y})^2}} \quad (2)$$

2.3 模板攻击

模板攻击的实施分为两个阶段，特征提取阶段与密钥恢复阶段。特征提取阶段攻击者拥有一台建模设备。攻击者利用从建模设备采集到的大量能量迹准确刻画目标设备执行不同时刻的能量泄露信息，亦称为模板。模板攻击中假设目标设备执行不同时刻能量泄露信息中噪声分量服从多元正态分布，且目标设备执行不同时刻能量泄露信息中信号分量与噪声分量相互独立。因此，攻击者使用均值向量与协方差矩阵刻画目标密码设备执行不同时刻能量泄露信息中信号分量与噪声分量，即，每个模板由均值向量与协方差矩阵构成。密钥恢复阶段，攻击者利用从目标设备采集到的能量迹恢复目标设备所使用密钥。攻击者使用最大似然准则计算从目标设备采集到的能量迹与所刻画不同模板的匹配概率，攻击者认为使得二者匹配概率最高的模板所对应密钥猜测为目标设备所使用密钥。

3 中间值碰撞能量分析攻击

与侧信道碰撞攻击相似，中间值碰撞能量分析攻击同样利用密码设备中密码算法某些中间值发生碰撞的特性实施密钥恢复。然而，与侧信道碰撞攻击不同之处在于中间值碰撞能量分析攻击不需要攻击者知道密码设备中密码算法细节。因此，中间值碰撞能量分析攻击在实际攻击场景中更加适用。

假设 f 函数为密码算法某个功能函数， p 与 k 分别为明文与密钥的部分比特， p 与 k 长度为 w 位，密钥总长度为 L 位， $w < L$ 。满足公式(3)时，密码算法中间值发生碰撞。以AES-128为例，第一轮中发生碰撞的操作见公式(4)，其中， p 与 k 为单字节， $w = 8$ ，子密钥空间大小 $n = 2^w = 256$ ， $0 \leq k \leq n - 1$ 。在交叉碰撞能量分析攻击中，攻击者不需要知道 f 函数的算法细节，利用密码设备中密码算法执行过程发生中间值碰撞的特点实施攻击。具体地，攻击过程分为建模与攻击两个阶段。本文以攻击目标设备使用密钥的第 j 个字节为例，介绍交叉碰撞能量分析攻击的具体实施过程。

$$f(p, k) = f(k, p) \quad (3)$$

$$SR(S(p \oplus k)) = SR(S(k \oplus p)) \quad (4)$$

3.1 建模阶段

为刻画目标设备中密码算法发生中间值碰撞位置的泄露信息，假设攻击者拥有 a 个与目标设备同类型的建模设备。同类型是指建模设备与目标设备类型相同，二者实现了相同的密码算法，且具有相似的物理泄露特征。 a 个建模设备的密钥已知，且不完全相同，同时，攻击者不能对建模设备的密钥进行修改。

a 个密钥构成的矩阵记为 $K_1 = \begin{bmatrix} k_{1,1}, \dots, k_{1,b} \\ \vdots \\ k_{a,1}, \dots, k_{a,b} \end{bmatrix}$ ，其中 $0 \leq ki,j \leq n - 1$ ， $a \geq 1$ ，

$b = L \setminus W$ ，例如，AES-128中 $b = 16$ 。攻击者用每个建模设备分别加密 n 个明

文， n 个明文构成的矩阵记为 $P = \begin{bmatrix} p_{1,1}, \dots, p_{1,b} \\ \vdots \\ p_{n,1}, \dots, p_{n,b} \end{bmatrix}$ 明文的第 j 列表示为 $P(:, j)$ ，

$1 \geq j \geq b$ ， $P(:, j)$ 为向量 $[0, \dots, n - 1]$ 的一个随机置换。共进行 d 次加密操作， $d = n \times a$ 。为每次加密过程采集一条能量迹， d 次加密操作得到的能量迹构成

的矩阵记为 $T = \begin{bmatrix} t_{1,1}, \dots, t_{1,m} \\ \vdots \\ t_{d,1}, \dots, t_{d,m} \end{bmatrix}$ m 为能量迹样本点数。根据给定的密钥 $k_{i,j}$ 和

明文 $p_{r,j}$ 可以找出对应的能量迹，至此，建模阶段结束。

3.2 攻击阶段

将建模阶段的密钥 K_1 当作攻击阶段的明文 P_2 , $K_1 = P_2 = \begin{bmatrix} \mathcal{P}_{1,1}, \dots, \mathcal{P}_{1,b} \\ \vdots \\ \mathcal{P}_{a,1}, \dots, \mathcal{P}_{a,b} \end{bmatrix}$

其中, $\mathcal{P}_{r,j} = k_{r,j}$, $1 \leq r \leq a$ 且 $1 \leq j \leq b$ 。用目标设备加密明文 P_2 , 采

集得到的能量迹构成的矩阵记为 $T = \begin{bmatrix} \tau_{1,1}, \dots, \tau_{1,m} \\ \vdots \\ \tau_{a,1}, \dots, \tau_{a,m} \end{bmatrix}$ 对于目标设备密钥猜

测 $0 \leq k \leq n-1$, 存在 $p_{x,j}$ 满足 $p_{x,j} = k$, 其中 $1 \leq x \leq n$ 。攻击阶段与建模阶段中间值发生碰撞, 见公式(5)。

$$f(\mathcal{P}_{r,j}, k) = f(k_{r,j}, p_{x,j}) \quad (5)$$

利用攻击阶段密钥猜测 k 与明文 $\mathcal{P}_{r,j}$, 根据公式(5)查找到对应建模阶段的密钥 $k_{r,j}$ 与明文 $p_{x,j}$, 从建模阶段刻画得到能量迹矩阵 T 中提取出 a 条能量迹, 将 a 条能量迹所构成的矩阵记作 T_1 , 计算矩阵 T_1 与矩阵 T_2 的对应列之间的统计相关性。密钥猜测 k 正确时, 发生碰撞的中间值对应的能量迹中的位置会出现显著相关性尖峰, 而在未发生碰撞位置或密钥猜测 k 错误时, 没有显著的相关性尖峰, 根据攻击结果恢复出正确密钥。

Algorithm 1 中间碰撞能量分析攻击

Require: (n, m, T_1, T_2) : n 为子密钥空间大小, m 为能量迹中样本点数, T_1 为建模阶段采集到的能量迹所构成矩阵, T_2 为攻击阶段采集到的能量迹所构成矩阵。

Ensure: C 为规模为 $n \times m$ 的相关系数矩阵

```

1: C=zeros(n,m)
2: for  $k = 0$  to  $n-1$  do
3:   for  $q = 0$  to  $m-1$  do
4:     C(k,q)=corr(T1(:,q),T2(:,q))
5:   end for
6: end for
7: return C
```

算法1展示了计算矩阵 T_1 与矩阵 T_2 对应列的统计相关性的过程。具体地, 第4步为计算矩阵 T_1 与矩阵 T_2 所对应列的统计相关系数。攻击者可得到一个

小为 $n \times m$ 的矩阵，将其记为 $C \begin{bmatrix} c_{1,1}, \dots, c_{1,m} \\ \vdots \\ c_{n,1}, \dots, c_{n,m} \end{bmatrix}$ 正确密钥猜测导致 C 中最大值

出现，因此，通过查找矩阵 C 中的最大值，可以确定出正确密钥索引值。

为提升攻击效果，将矩阵 C 进行处理，删除 C 中当前密钥猜测 k 对应的相关系数行，然后对 C 的每一列求方差或标准差。在中间值未发生碰撞的位置，当前密钥猜测对应的相关系数与方差或标准差相减后得到的差值较小；在中间值发生碰撞的位置，错误密钥猜测对应的相关系数与方差或标准差相减后得到的差值较小，正确密钥猜测对应的相关系数与方差或标准差相减后得到的差值显著。因此，可以通过上述技术进一步提升正确密钥猜测相对于错误密钥猜测的区分度。

Algorithm 2 改进的中间碰撞能量分析攻击

Require: (n, C) : n 为子密钥空间大小， C 为相关系数矩阵。

Ensure: D 为改进的矩阵。

```

1: for  $k = 0$  to  $n - 1$  do
2:    $B = C$ 
3:    $B(k, :) = []$ 
4:    $B(k, :) = \text{var}(B)$ 
5: end for
6:  $D = C - B$ 
7: return  $D$ 

```

算法2展示了计算改进的矩阵 D 的过程。具体地，第3步矩阵 B 中删除当前密钥猜测 k 对应的相关系数行 $B(k, :)$ 。第4步，对 B 矩阵每列求方差或标准差。最后，在第6步计算得到改进矩阵 D 。同样，通过查找矩阵 D 中的最大值，可以确定出正确密钥索引值。

4 实验

为了验证中间值碰撞能量分析攻击的有效性，本文对实现于STC89C58微控制器的无保护AES-128软件实现实施了攻击。我们在微控制器电源端串联一个 50Ω 电阻，使用安捷伦DSA90404A数字示波器提供的差分探针测量该电阻两端的电压降。微控制器的时钟频率设置为11MHz，示波器采样率设置为50MS/s。实验要求能量迹对齐，即不同能量迹在相同时刻的能量消耗值对应密码设备中密码算法的同一操作过程。采集得到每条能量迹包含100,000个样本

点。为降低电子噪声，对相同明文与密钥的100条能量迹求均值得到1 条能量迹。为提高攻击效率，采用原始整合方法[13]对能量迹进行预处理，将每20个采样点压缩为一个点，压缩后每条能量迹包含5000个样本点。

建模阶段写入64次随机密钥，模拟64个密钥已知的建模设备。使用每个密钥加密256个明文并得到256条对应的能量迹，共得到 $256 \times 64 = 16,384$ 条能量迹。攻击阶段写入一个密钥以作为目标设备。最后，将建模阶段所使用的64个密钥当作攻击阶段所使用的明文进行加密，并采集得到64条能量迹，然后实施中间值碰撞能量分析攻击。

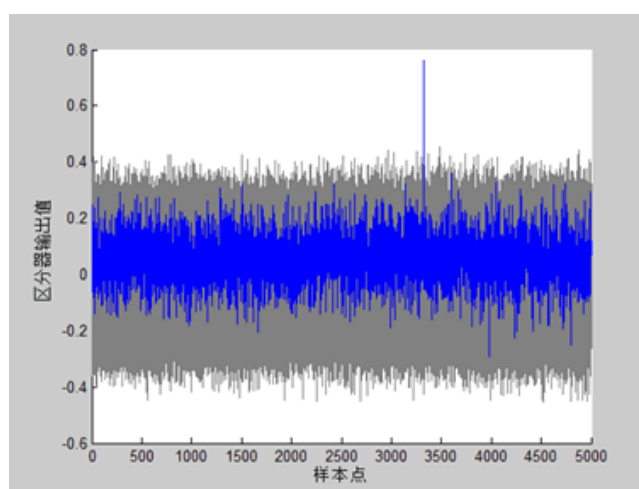


图 1: 基于AES-128无保护软件实现的实际评估结果

图1展示了选取AES-128第7个密钥字节（值为135）作为攻击对象，对相关系数矩阵进行改进后的攻击结果。可见正确密钥对应的区分器输出值中存在明显尖峰。

表 1: 针对不同密钥字节的攻击效果

字节	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
方差	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
均值	1	1	1	1	1	1	1	1	1	3	1	2	1	1	1	1

对每个密钥猜测对应相关系数矩阵D中最大值按降序排列。表1展示了中间值碰撞能量分析攻击针对不同密钥字节的攻击结果。表1中值为1表示正确密钥值在密钥猜测排序中第1个位置出现，采用方差函数时，目标设备所有密钥字节都能攻击成功。相比较而言，采用均值函数时效果不如采用方差函数效果理想。

总体而言，实际评估结果表明中间值碰撞能量分析攻击能够有效恢复出目标设备所使用的密钥。

5 结论

在攻击者未知密码设备中密码算法细节，并且不具备对建模设备进行重写密钥的能力时，已有能量分析攻击方法失效。基于此，本文提出了一种新型中间值碰撞能量分析攻击，该攻击利用明文与密钥交换后密码设备中密码算法某些中间值保持不变的特性实施密钥恢复。与已有攻击相比，该攻击的最大特点在于不要求知道密码设备中密码算法细节，攻击者仅需要拥有少量与目标设备同类型的建模设备，不同建模设备所使用密钥不尽相同并且攻击者无需对建模设备所使用的密钥进行修改。最后，本文在实现于STC89C58微控制器的AES-128无保护软件实现上验证了该方法的有效性。中间值碰撞能量分析攻击的提出将会为密码设备的物理安全性分析与检测提供技术方法支持。

参考文献

- [1] Paul Kocher, Joshua Jaffe, and Benjamin Jun. Differential Power Analysis[J]. CRYPTO, 1999, 1666: 388-397.
- [2] Eric Brier, Christophe Clavier, and Francis Olivier. Correlation Power Analysis with a Leakage Model[J]. CHES, 2004, 3156: 16-29.
- [3] Youssef Souissi, Nicolas Debande, Sami Mekki, Sylvain Guilley, Ali Maalaoui, Jean-Luc Danger. On The optimality of Correlation Power Attack On Embedded Cryptographic Systems[J]. WISTEP, 2012, 7332: 169-178.
- [4] Suresh Chari, Josyula R. Rao, Pankaj Rohatgi. Template Attacks[J]. CHES, 2002, 2523: 13-28.
- [5] Lejla Batina, Benedikt Gierlichs, Emmanuel Prouff, Matthieu Rivain, François-Xavier Standaert, and Nicolas Veyrat-Charvillon. Mutual Information Analysis: A Comprehensive Study[J]. Journal of Cryptology, 2011, 24(2):269-291.
- [6] Benedikt Gierlichs, Lejla Batina, Pim Tuyls, Bart Preneel. Mutl Information Analysis: A Generic Side-Channel Distinguisher[J]. CHES, 2008, 5154: 426-442.
- [7] Carolyn Whittall, Elisabeth Oswald. A Comprehensive Evaluation of Mutual Information Analysis Using a Fair Evaluation Framework[J]. CRYPTO, 2011, 6841: 316-334.
- [8] Vanessa Gratzner, and David Naccache. Blind Attacks on Engineering Samples[J]. IACR Cryptology ePrint Archive, 2005, 468: 1-3.
- [9] Benoît Gérard and François-Xavier Standaert. Unified and Optimized Linear Collision Attacks and Their Application in a Non-profiled Setting[J]. CHES, 2012, 7428: 175-192.
- [10] Amir Moradi, Oliver Mischke, Thomas Eisenbarth. Correlation Enhanced Power Analysis Collision Attack[J]. CHES, 2010, 6225: 125-139.
- [11] Amir Moradi, Statistical Tools Flavor Side-Channel Collision Attacks[J]. EUROCRYPT, 2012, 723: 428-445.

- [12] Xin Ye, Thomas Eisenbarth. Wide Collisions in Practice[J]. Applied Cryptography and Network Security, 2012, 7341: 329-343.
- [13] Stefan Mangard, Elisabeth Oswald, Thomas Popp. Power Analysis Attacks Revealing the Secrets of Smart Cards[M]. New York: Springer, 2007.